

Практическое руководство: 3 недели упражнений по пентесту

Практическое руководство — закрепление навыков активного сбора информации и сканирования

Этот PDF — практическая рабочая тетрадь на 2-3 недели для закрепления навыков: Kali/Linux, Bash, Netcat, Wireshark, DNS, Nmap, Masscan, SMB/NFS/SNMP и OSINT-инструменты. Каждое упражнение — конкретная задача с ожидаемым результатом и предложенным форматом отчёта.

Неделя 1 — Вспоминаем базу (Kali, Bash, nc, tcpdump/wireshark)

- Linux Essentials: 5 практических команд с пайпом и перенаправлением. Сохрани в `~/pentest/notes.md`.
- Скрипт `sysinfo.sh`: выводит IP, hostname, uptime, top3 CPU, использование памяти. Сохранить в `~/pentest/scripts/`.
- `scan_subnet.sh`: принимает подсеть (например 192.168.56.0/24), пингует хосты и формирует список активных IP.
- `port_check.sh`: проверка порта через netcat (`nc -zv`). Используй для проверки 22,80,443,445.
- `log_monitor.sh`: следит за `/var/log/auth.log` и выводит неудачные попытки SSH (используй `tail -F` и `grep`).
- Практика Netcat: передача файла локально (`nc -lvp 1234 > file`) и клиент (`nc host < file`). Сохрани `pcap tcpdump`.

Неделя 2 — Пассивный сбор информации (OSINT)

- WHOIS и DNS: выполни `whois`, `dig`, `nslookup` для 3 доменов. Сохрани важные поля (`registrar`, `nameservers`, `creation/expiry`).
- Google Dorking: составь 10 dork-запросов для поиска логинов, конфиденциальной и публичных ключей. Сохрани в `dorks.txt`.
- theHarvester / recon-ng: собрать e-mails и поддомены для тестового домена (lab). Экспорт отчёта.
- Shodan: практическая выборка по стране/порту (только в учебной среде). Составь `shodan_findings.txt` с 5 интересными устройствами.

Неделя 3 — Активный сбор информации (Scanning)

- Nmap: три скана — быстрый (SYN, первые 1000 портов), подробный (`-sV -O -A`), скриптовый (`--script vuln`). Сохрани в `nmap-reports/`.
- Masscan: быстрый полный портскан по подсети с ограниченным rate. Сравни output `masscan.out` с nmap и определи расхождения.
- DNS enumeration: `dnsenum`, `fierce`, `amass/subfinder` — собрать список поддоменов, возможности AXFR в lab.
- SMB/NFS/SNMP: `enum4linux`, `smbclient`, `smbmap`, `showmount`, `snmpwalk`. Документ найденные шары, права и возможные секреты.

Доп. мини-проекты (выходные)

- Автоматизация: `recon_automator.sh` — принимает домен и выполняет `whois`, `dig`, `theHarvester`, `shodan` (если есть API) и сохраняет отчёт.
- Лаб: установи Metasploitable/VulnHub VM, проведи полный Recon, составь `final-report.md` с доказательствами (nmap, smb, snmp, pcap).
- Wireshark challenge: захват трафика, найти HTTP/DNS/FTP сессии; попытаться реконструировать загруженный файл или кредиты (в локальной lab).

Шаблон отчёта (копируй в `report.md`):

[Дата] [Цель] Инструменты: nmap, masscan, dig, enum4linux, smbclient, snmpwalk 1) Summary (Кратко): найденные цели, критичность 2) Masscan / Nmap outputs (путь к файлам) 3) Per-service findings (по порту) 4) Возможные пути эксплуатации 5) Рекомендации 6) Приложения: pcap, скрипты, raw outputs

Чек-лист перед сканированием (коротко)

- Убедиться, что цель — разрешённая лабораторная VM. Записать IP/VM name и port.
- Quick masscan → nmap. Сохранить результаты в timestamped директории.
- По каждому открытому порту: определить сервис и версию, затем подобрать и выполнить для эnumерации.

Pentest Practice Guide — продолжение

Практическое руководство — закрепление навыков активного сбора информации и сканирования

- Сохранить все выводы, рсар и скрипты в `/pentest/reports/<target>/`
- После работы — удалить временные файлы, зашифровать `/secure-store` найденные креды.

Советы по запоминанию

- Active recall: воспроизводи команды по памяти, а затем сверяйся.
- Spaced repetition: повторяй ключевые команды каждые 2 недели.
- Document everything: отчёт — твой главный продукт.
- Explainer: раз в неделю записывай 5-мин видео, где объясняешь одно упражнение.

Сгенерировано: Персональный практический гайд — тренировка Pentest. Удачи!